Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys

Implementation Solution Guide

Version 1.0.0 · 2026-06-28

Contents

Executive Summary — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys (Microsoft Entra ID) 4

What you get . . . 4

What this delivers . . . 4

The deployment model . . . 4

Outcome . . . 4

1. Solution Overview — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys 5

What phishing-resistant, passwordless authentication is . . . 5

How it works . . . 5

FIDO2 keys vs. Windows Hello for Business vs. certificate-based auth . . . 5

Conditional Access authentication strengths (the enforcement layer) . . . 5

What you can control . . . 6

Benefits . . . 6

Limitations (be honest with buyers) . . . 6

The standard deployment model . . . 6

2. Requirements Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys 6

2.1 Licensing . . . 6

2.2 Admin roles . . . 7

2.3 Break-glass accounts . . . 7

2.4 Authentication methods policy available . . . 7

2.5 FIDO2 security keys (hardware + support) . . . 7

2.6 Windows Hello for Business readiness . . . 7

2.7 (Optional) Certificate-based authentication . . . 7

2.8 Conditional Access readiness . . . 8

2.9 Pilot and rollout groups . . . 8

Checklist . . . 8

Global Requirements — Entra ID Solutions (category-level) 8

G1. Microsoft Entra ID tenant . . . 8

G2. Entra ID licensing (P1 / P2) . . . 8

G3. Administrative roles . . . 9

G4. Break-glass (emergency-access) accounts . . . 9

G5. Authentication methods policy access . . . 9

G6. Conditional Access baseline . . . 9

G7. Network access to Microsoft cloud endpoints . . . 9

3. Implementation Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys 10
Step 1 — Create the groups . . . 10
Step 2 — Enable FIDO2 security keys . . . 10
Step 3 — Enable Windows Hello for Business . . . 10
Step 4 — (Optional) Enable certificate-based authentication . . . 10
Step 5 — Launch the registration campaign . . . 10
Step 6 — Create the phishing-resistant authentication strength . . . 11
Step 7 — Enforce on the pilot via Conditional Access . . . 11
Step 8 — Validate the pilot . . . 11
Step 9 — Expand to all staff . . . 11
5. Testing Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys 12
Test 1 — Methods enabled . . . 12
Test 2 — User can register a FIDO2 key . . . 12
Test 3 — Passwordless sign-in works . . . 12
Test 4 — Registration coverage . . . 12
Test 5 — Authentication strength exists . . . 12
Test 6 — Conditional Access enforces the strength . . . 12
Test 7 — Break-glass unaffected . . . 12
Pass/fail gate . . . 13
6. Troubleshooting Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys 13
A. Users locked out after enforcement . . . 13
B. FIDO2 key won't register . . . 13
C. Windows Hello for Business not provisioning . . . 13
D. Conditional Access not requiring the strength . . . 14
E. Certificate-based authentication failing . . . 14
F. Diagnostics quick reference (Microsoft Graph PowerShell) . . . 14
G. When to escalate . . . 14
7. Best Practices — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys 14
8. Deliverables Summary — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys 15
Documentation . . . 15
PowerShell scripts . . . 15
What the buyer receives . . . 16
Outcome . . . 16
Appendix A — PowerShell Scripts 17

Executive Summary — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys (Microsoft Entra ID)

White-label · Entra ID Solutions

Passwords get phished, and even push-based MFA gets bombed until a tired user taps "Approve." Security-conscious and federal organizations are now expected to move to **phishing-resistant**, passwordless authentication. This solution stands up **passwordless and phishing-resistant MFA in Microsoft Entra ID** — FIDO2 hardware security keys, Windows Hello for Business, and (where applicable) certificate-based authentication — enabled as authentication methods, registered by users through a campaign, and then **enforced** through a Conditional Access authentication strength so weak, phishable methods can no longer get in.

This is a complete, **deploy-it-today** package for a competent administrator with no prior passwordless experience: every screen, every object name, every gate.

What you get

• A plain-language **Solution Overview** of the Entra ID authentication methods model, FIDO2 keys vs. Windows Hello for Business vs. certificate-based auth, and Conditional Access authentication strengths — including *why* each is used.

• A **Requirements Guide** with verify / implement-if-missing for every prerequisite.

• An **Implementation Guide** of precise, click-by-click steps in the required order.

• Five **PowerShell scripts** for auth-methods readiness discovery, per-user passwordless registration validation, a tenant credential-method coverage report, safe remediation of weak-method users, and a rollout target-group builder.

• **Testing** and **Troubleshooting** guides with explicit pass/fail gates.

What this delivers

A **phishing-resistant credential program** — FIDO2 security keys and Windows Hello for Business registered across a pilot then the staff, a named **authentication strength** (`Phishing-Resistant`) created once, and a Conditional Access policy that **requires** that strength so legacy password+SMS/push sign-ins are blocked. This is broader than a single Windows Hello deployment: it is the whole passwordless and phishing-resistant enforcement program.

The deployment model

Assess → **Configure** → **Pilot** → **Validate** → **Expand** — with a pilot gate before any enforcement reaches all staff.

Outcome

Users signing in passwordless with phishing-resistant credentials, weak methods blocked by a Conditional Access authentication strength, and break-glass access preserved — proven on a pilot before you scale, deployable by a single administrator.

1. Solution Overview — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys

What phishing-resistant, passwordless authentication is

Passwordless means a user signs in **without typing a password** — proving identity with a hardware-backed credential bound to the device or a security key. Phishing-resistant means the credential **cannot be replayed against an attacker's fake site**: it is cryptographically bound to the real sign-in origin, so a phished code or an approved push can't be reused. In Microsoft Entra ID, the phishing-resistant, passwordless methods are **FIDO2 security keys**, **Windows Hello for Business**, and **certificate-based authentication** (smart cards / PIV-CIV). This solution turns those on, gets users registered, and then enforces them.

How it works

1. Entra ID's **Authentication methods** policy enables each method (FIDO2, Windows Hello for Business, certificate-based auth) and scopes *who* can register it.

2. Users **register** a credential — tapping/plugging a FIDO2 key, enrolling Windows Hello, or being issued a certificate — at the security-info portal or during a **registration campaign** that nudges them at sign-in.

3. A Conditional Access **authentication strength** defines the set of acceptable methods (here, the built-in *Phishing-resistant MFA* strength, or a custom one).

4. A Conditional Access **policy** requires that strength for the targeted users, so a password+SMS or password+push sign-in is **blocked** — only a phishing-resistant credential satisfies the grant.

5. Coverage and registration are reported from Entra (registration details) so you can see who is ready before you enforce.

FIDO2 keys vs. Windows Hello for Business vs. certificate-based auth

• **FIDO2 security keys** — a portable hardware key (USB/NFC) the user taps. Best for shared workstations, kiosks, frontline, and admins who roam between machines. Phishing-resistant by design.

• **Windows Hello for Business** — a credential bound to a specific Windows PC, unlocked by PIN or biometric. Best for assigned, single-user devices. (A standalone Windows Hello product covers enrollment depth; this program *includes* Windows Hello but centers on the broader passwordless + FIDO2 rollout and enforcement.)

• **Certificate-based authentication** — X.509 certificates / smart cards. Best where a PKI or PIV/CIV cards already exist (often federal).

Conditional Access authentication strengths (the enforcement layer)

An **authentication strength** is a named, reusable set of allowed authentication-method combinations. Entra ships a built-in **Phishing-resistant MFA** strength (FIDO2, Windows Hello for Business, certificate-based auth). You reference it from a Conditional Access grant to *require* a phishing-resistant

sign-in. This is what makes the program real — without it, weak methods still work.

What you can control

- Which methods are enabled and **who may register** each (per-group scoping).
- A **registration campaign** that prompts users to add a phishing-resistant method at sign-in.
- The **authentication strength** required (built-in phishing-resistant, or a custom strength).
- The Conditional Access **scope** (pilot group first, then all staff), with break-glass exclusions.

Benefits

- **Phishing-resistant** — credentials can't be replayed against fake sites; push-bombing stops working.
- **Passwordless** — no password to phish, spray, or reuse; better user experience.
- **Mandate-ready** — meets executive/federal requirements for phishing-resistant MFA.
- **Enforceable** — Conditional Access authentication strengths block weak methods, not just recommend strong ones.
- **Measurable** — registration and method-coverage reporting before and after enforcement.

Limitations (be honest with buyers)

- FIDO2 keys and certificate-based auth need **hardware** (keys, or a PKI/smart-card stack) — a procurement and distribution step.
- Enforcing a phishing-resistant strength **before** users are registered will lock them out — registration must lead enforcement (hence the pilot gate).
- Certificate-based authentication requires a configured certificate authority and trust chain in Entra.
- Some legacy/line-of-business apps and protocols don't honor modern auth; inventory them before tenant-wide enforcement.

The standard deployment model

> ***Enable methods → register users (campaign) → create the phishing-resistant authentication strength → require it via Conditional Access on the pilot → validate → expand to all staff.***
> *Pattern:* ***Assess → Configure → Pilot → Validate → Expand.***

2. Requirements Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites are in `global-requirements-entra-id-solutions.md`.

2.1 Licensing

Description: Entra ID P1 (Conditional Access + authentication strengths); P2 only if you add risk-based enforcement. **Why:** Authentication strengths are delivered through Conditional Access, which requires P1. **Verify:** M365 admin center → **Billing** → **Licenses** (Entra ID P1/P2 is included in M365 E3/E5 and Business Premium). **Implement:** Assign M365 E3/E5, Business Premium, or standalone Entra ID P1.

2.2 Admin roles

Description: Authentication Policy Administrator + Conditional Access Administrator for the operator. **Why:** You will edit the Authentication methods policy and create Conditional Access policies. **Verify:** Entra → **Roles and administrators**. **Implement:** Assign both roles; reserve Global Administrator for tenant-wide changes.

2.3 Break-glass accounts

Description: Two cloud-only emergency-access accounts excluded from Conditional Access. **Why:** An authentication-strength policy can lock out all admins; break-glass preserves access. **Verify:** Entra → **Users**; two `*.onmicrosoft.com` accounts excluded from every CA policy. **Implement:** Create them, store credentials offline, exclude from all CA policies, monitor sign-ins. (See global G4.)

2.4 Authentication methods policy available

Description: The converged **Authentication methods** policy is in use (not the legacy MFA settings). **Why:** FIDO2, Windows Hello for Business, and certificate-based auth are enabled here. **Verify:** Entra → **Protection** → **Authentication methods** → **Policies** opens; run `FIDO2-Discovery.ps1`. **Implement:** Migrate from legacy MFA/SSPR method settings to the Authentication methods policy.

2.5 FIDO2 security keys (hardware + support)

Description: FIDO2-certified security keys procured for the in-scope users; modern browsers/OS for WebAuthn. **Why:** FIDO2 is the portable, phishing-resistant credential for roaming users and admins. **Verify:** Keys on hand; user devices on a supported OS/browser; run `FIDO2-Discovery.ps1` (FIDO2 method state). **Implement:** Procure FIDO2 keys; optionally restrict to specific key models by AAGUID in the FIDO2 method settings.

2.6 Windows Hello for Business readiness

Description: Windows 10/11 devices able to provision Windows Hello (Entra-joined or hybrid). **Why:** Windows Hello is the device-bound passwordless credential for assigned PCs. **Verify:** Devices are Entra-joined/registered; run `FIDO2-Discovery.ps1`. **Implement:** Enable Windows Hello for Business (Intune policy or the Authentication methods policy); ensure TPM present.

2.7 (Optional) Certificate-based authentication

Description: A configured certificate authority and trust chain in Entra, plus issued certificates/smart cards. **Why:** Required only if certificate-based auth is part of the program (often federal/PIV). **Verify:** Entra → **Protection** → **Show more** → **Certificate-based authentication** shows CAs configured. **Implement:** Upload the CA chain and configure username binding before enabling the method.

2.8 Conditional Access readiness

Description: Conditional Access available; an app/service inventory for tenant-wide enforcement. **Why:** Enforcement uses an authentication-strength grant; legacy apps may not honor it. **Verify:** Entra → **Protection** → **Conditional Access** → **Policies**; run `FIDO2-Report.ps1` for current method coverage. **Implement:** Plan policy scope; start in **Report-only**; identify exclusions for legacy protocols. (See global G6.)

2.9 Pilot and rollout groups

Description: Entra security groups for the pilot and the broad/all-staff rollout. **Why:** Method scoping, the registration campaign, and CA enforcement target groups, piloted first. **Verify:** Entra → **Groups**; pilot + rollout groups exist (or build with `FIDO2-Set-RolloutTargeting.ps1`). **Implement:** Create `Phishing-Resistant – Pilot – Users` and `Phishing-Resistant – All Staff – Users`.

Checklist

- Entra ID P1 licensing assigned
- Authentication Policy + Conditional Access Administrator roles
- Two break-glass accounts excluded from CA
- Authentication methods policy in use — `FIDO2-Discovery.ps1`
- FIDO2 keys procured; OS/browser supported
- Windows Hello for Business readiness confirmed
- (Optional) Certificate-based authentication CA configured
- Conditional Access ready; legacy-app exclusions identified
- Pilot + rollout Entra groups created

Global Requirements — Entra ID Solutions (category-level)

These requirements apply to **every** solution in the **Entra ID Solutions** category. They are published once at the category level so individual listings stay small. Confirm these before deploying *any* Entra ID identity solution. Each entry: **Description · Why · Verify · Implement-if-missing.**

G1. Microsoft Entra ID tenant

Description: An active Microsoft Entra ID tenant. **Why:** It is the identity backbone that issues credentials, evaluates Conditional Access, and stores authentication methods. **Verify:** Sign in to `https://entra.microsoft.com` as an administrator; the tenant Overview loads. **Implement:** Create a Microsoft 365 / Azure subscription, which provisions a tenant.

G2. Entra ID licensing (P1 / P2)

Description: Entra ID P1 for Conditional Access; P2 for risk-based policies and Identity Protection. **Why:** Conditional Access authentication strengths require P1; risk-driven enforcement requires P2. **Verify:** Entra → **Overview**; or M365 admin center → **Billing** → **Licenses** (look for Entra ID P1/P2, included in M365 E3/E5 and Business Premium). **Implement:** Assign M365 E3/E5, Business Premium, or standalone Entra ID P1/P2.

G3. Administrative roles

Description: Appropriate Entra admin roles for the operator. **Why:** Editing authentication methods and Conditional Access requires elevated rights. **Verify:** Entra → **Roles and administrators**; confirm **Authentication Policy Administrator** (methods) and **Conditional Access Administrator** (policies). **Implement:** Assign **Authentication Policy Administrator** + **Conditional Access Administrator**; reserve **Global Administrator** for tenant-wide changes.

G4. Break-glass (emergency-access) accounts

Description: At least two cloud-only emergency-access accounts excluded from Conditional Access. **Why:** A misconfigured authentication-strength or MFA policy can lock out every admin; break-glass accounts preserve access. **Verify:** Entra → **Users**; two `*.onmicrosoft.com` accounts exist and are excluded from all CA policies. **Implement:** Create two cloud-only Global Administrator accounts with long passphrases, store credentials offline, exclude them from every CA policy, and monitor their sign-ins.

G5. Authentication methods policy access

Description: The tenant uses the **Authentication methods** policy (the modern, converged surface) to manage methods. **Why:** FIDO2, Windows Hello for Business, and certificate-based auth are enabled here, not in legacy per-method blades. **Verify:** Entra → **Protection** → **Authentication methods** → **Policies** opens. **Implement:** If still on the legacy MFA/SSPR method settings, migrate to the Authentication methods policy (Microsoft's guided migration toggle).

G6. Conditional Access baseline

Description: Conditional Access is available and at least a baseline MFA policy exists (or security defaults are understood). **Why:** Phishing-resistant enforcement is delivered through Conditional Access authentication strengths. **Verify:** Entra → **Protection** → **Conditional Access** → **Policies** lists policies; security defaults state is known. **Implement:** Disable security defaults only when replacing them with explicit CA policies; start in **Report-only** before enforcing.

G7. Network access to Microsoft cloud endpoints

Description: Outbound HTTPS to Microsoft 365 / Entra sign-in and registration endpoints. **Why:** Method registration, sign-in, and policy evaluation depend on these endpoints. **Verify:** From a device, reach `https://login.microsoftonline.com` and `https://aka.ms/mysecurityinfo`. **Implement:** Allow Microsoft's published Microsoft 365 / Entra URL & IP ranges through proxy/firewall.

The deployment model (all solutions): Assess → Configure → Pilot → Validate → Expand.

3. Implementation Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys

Follow these steps **in order**, in the **Microsoft Entra admin center** (`https://entra.microsoft.com`).

> ***Model:*** *Enable the methods, get a **pilot** registered, create a phishing-resistant authentication strength, require it via Conditional Access on the pilot, validate, then expand to all staff. Registration always leads enforcement so no one is locked out.* ***Naming convention*** *— every object uses* `<Purpose> – <Scope> – <Stage>`*. Create these and reuse the names verbatim: - Groups:* `Phishing-Resistant – Pilot – Users`*,* `Phishing-Resistant – All Staff – Users` *- Authentication strength:* `Phishing-Resistant – All Staff – Standard` *- Conditional Access (pilot):* `Phishing-Resistant – Pilot – Enforce` *- Conditional Access (broad):* `Phishing-Resistant – All Staff – Enforce`

Step 1 — Create the groups

1. Entra → **Groups** → **New group** → **Security** → name `Phishing-Resistant – Pilot – Users` (a few representative users + admins). **Create**.
2. Create `Phishing-Resistant – All Staff – Users` (everyone in scope). **Create**.

Step 2 — Enable FIDO2 security keys

1. Entra → **Protection** → **Authentication methods** → **Policies** → **FIDO2 security key**.
2. Set **Enable** to **Yes**; **Target** to `Phishing-Resistant – Pilot – Users` (expand later).
3. Under **Configure**: leave **Allow self-service set up** = Yes; optionally restrict key models by AAGUID. **Save**.

Step 3 — Enable Windows Hello for Business

1. Entra → **Protection** → **Authentication methods** → **Policies** → **Windows Hello for Business** (or via Intune if you manage it there).
2. **Enable** and **Target** `Phishing-Resistant – Pilot – Users`. **Save**.

Step 4 — (Optional) Enable certificate-based authentication

1. Entra → **Protection** → **Show more** → **Certificate-based authentication**; confirm the CA chain is uploaded and username binding is set.
2. Then **Protection** → **Authentication methods** → **Policies** → **Certificate-based authentication** → **Enable**, **Target** the pilot. **Save**.

Step 5 — Launch the registration campaign

1. Entra → **Protection** → **Authentication methods** → **Registration campaign**.
2. Set **State** = **Enabled**; **Include** `Phishing-Resistant – Pilot – Users`; choose the methods to nudge (authenticator/passwordless). **Save**.

3. Direct pilot users to `https://aka.ms/mysecurityinfo` to register a FIDO2 key or Windows Hello now.

Step 6 — Create the phishing-resistant authentication strength

1. Entra → **Protection** → **Authentication methods** → **Authentication strengths**.

2. Use the built-in **Phishing-resistant MFA** strength, or **New authentication strength** named `Phishing-Resistant – All Staff – Standard` and select FIDO2, Windows Hello for Business, and (if used) certificate-based auth. **Save**.

Step 7 — Enforce on the pilot via Conditional Access

1. Entra → **Protection** → **Conditional Access** → **Create new policy**. **Name:** `Phishing-Resistant – Pilot – Enforce`.

2. **Users:** include `Phishing-Resistant – Pilot – Users`; **exclude** the two break-glass accounts.

3. **Target resources:** All cloud apps (or a pilot app first).

4. **Grant: Require authentication strength** → select `Phishing-Resistant – All Staff – Standard` (or built-in Phishing-resistant MFA).

5. **Enable policy: Report-only** first. **Create**.

Step 8 — Validate the pilot

1. Have a pilot user sign in; confirm a phishing-resistant credential is requested (or, in Report-only, that it *would* be required).

2. Run `FIDO2-Validation.ps1` for a pilot user → confirms a phishing-resistant method is registered as default.

3. Run `FIDO2-Report.ps1` → confirms pilot coverage. Complete the **Testing Guide**. Then switch the pilot policy from **Report-only** to **On**.

Step 9 — Expand to all staff

1. Confirm registration coverage with `FIDO2-Report.ps1` for `Phishing-Resistant – All Staff – Users` (do not enforce ahead of registration).

2. Widen the method-policy **Target** and the registration campaign to `Phishing-Resistant – All Staff – Users`.

3. Create `Phishing-Resistant – All Staff – Enforce` (same grant), scope to all staff, exclude break-glass, run **Report-only**, then turn **On** once coverage is high. Use `FIDO2-Remediation.ps1` (default `-WhatIf`) to help laggards.

Order of operations

`Groups → enable FIDO2 → enable Windows Hello → (certificate-based) → registration campaign → authentication strength → CA enforce on pilot →`

`validate → expand to all staff`

5. Testing Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys

Run after the pilot is configured (Implementation Step 8) and again before expanding to all staff.

Test 1 — Methods enabled

Do: Entra → **Protection** → **Authentication methods** → **Policies**; check FIDO2 and Windows Hello for Business; or run `FIDO2-Discovery.ps1`. **Expected:** FIDO2 and Windows Hello for Business are **Enabled** and **Targeted** at the pilot group.

Test 2 — User can register a FIDO2 key

Do: A pilot user goes to `https://aka.ms/mysecurityinfo` → **Add sign-in method** → **Security key** and registers a FIDO2 key. **Expected:** The key registers without error and appears in the user's security info.

Test 3 — Passwordless sign-in works

Do: The pilot user signs out and signs in using the FIDO2 key (or Windows Hello). **Expected:** Sign-in succeeds **without a password**.

Test 4 — Registration coverage

Do: Run `FIDO2-Validation.ps1 -UserId <pilot user>` and `FIDO2-Report.ps1`. **Expected:** The pilot user has a phishing-resistant method registered; the report shows pilot coverage rising.

Test 5 — Authentication strength exists

Do: Entra → **Protection** → **Authentication methods** → **Authentication strengths**. **Expected:** `Phishing-Resistant – All Staff – Standard` (or the built-in Phishing-resistant MFA) lists FIDO2 / Windows Hello / (certificate-based).

Test 6 — Conditional Access enforces the strength

Do: With `Phishing-Resistant – Pilot – Enforce` set to **On**, have a pilot user attempt password + SMS/push, then the phishing-resistant credential. **Expected:** Weak methods are **blocked**; the phishing-resistant credential **succeeds**.

Test 7 — Break-glass unaffected

Do: Confirm a break-glass account is excluded and can still sign in. **Expected:** Break-glass accounts are not subject to the strength policy.

Pass/fail gate

Gate	Requirement
Pilot pass	Tests 1–6 pass for the pilot group; break-glass excluded (Test 7)
Broad pass	Coverage high for all staff (Test 4) before `Phishing-Resistant – All Staff – Enforce` is turned **On**

6. Troubleshooting Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys

Use `FIDO2-Discovery.ps1` for tenant method state, `FIDO2-Validation.ps1` for a user's registered methods, `FIDO2-Report.ps1` for coverage, and `FIDO2-Remediation.ps1` (default `-WhatIf`) for laggards.

A. Users locked out after enforcement

Symptom	Cause	Remediation
Users can't sign in after the strength policy turns on	Enforced before users registered a phishing-resistant method	Set the CA policy to **Report-only**, drive registration via the campaign, confirm coverage with `FIDO2-Report.ps1`, then re-enable
Admins locked out	Break-glass accounts not excluded	Sign in with break-glass; exclude them from every CA policy (global G4)

B. FIDO2 key won't register

Symptom	Cause	Remediation
"Security key" option missing at `aka.ms/mysecurityinfo`	FIDO2 not enabled or user not targeted	Enable FIDO2 and target the user's group; run `FIDO2-Discovery.ps1`
Key rejected during registration	Key model blocked by AAGUID restriction, or unsupported browser/OS	Allow the model's AAGUID (or remove the restriction); use a supported browser/OS

C. Windows Hello for Business not provisioning

- Confirm the device is Entra-joined/registered and has a TPM; confirm Windows Hello for Business is enabled (Authentication methods policy or Intune) and the user is targeted.

D. Conditional Access not requiring the strength

Symptom	Cause	Remediation
Weak methods still work	Policy in Report-only, or wrong grant	Confirm the policy is **On** and the grant is **Require authentication strength** with the right strength selected
Some apps bypass it	Legacy/non-modern-auth apps/protocols	Inventory and remediate or scope them; don't leave permanent broad exclusions

E. Certificate-based authentication failing

- Confirm the CA chain is uploaded, the trust/issuer is valid, and username binding is configured before the method is enabled; check certificate validity/revocation.

F. Diagnostics quick reference (Microsoft Graph PowerShell)

```
Connect-MgGraph -Scopes 'Policy.Read.All','UserAuthenticationMethod.Read.All','AuditLog.Read.All'
# Tenant method policy (FIDO2 etc.)
Invoke-MgGraphRequest GET '/v1.0/policies/authenticationMethodsPolicy'
# A user's registered methods
Invoke-MgGraphRequest GET "/v1.0/users/<upn>/authentication/methods"
# Registration details (coverage)
Invoke-MgGraphRequest GET '/v1.0/reports/authenticationMethods/userRegistrationDetails'
```

G. When to escalate

If methods are enabled and targeted, the user has registered a phishing-resistant method, the CA policy grant is correct, and sign-in still fails, collect the Entra **Sign-in logs** entry (the failed CA policy + authentication-strength detail) and open a Microsoft support case.

7. Best Practices — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys

- **Register before you enforce.** Get users onto a phishing-resistant method *first*; turning on the authentication strength ahead of registration locks people out. This is the single most important rule.
- **Always keep break-glass accounts excluded.** Two cloud-only emergency accounts, excluded from every Conditional Access policy, monitored for sign-ins — your insurance against a bad policy.
- **Pilot, then expand.** Validate the full flow on `Phishing-Resistant – Pilot – Users` before widening to `Phishing-Resistant – All Staff – Users`.
- **Use Report-only first.** Every Conditional Access policy starts in **Report-only** so you see impact before anything is blocked.
- **Run the registration campaign.** A sign-in nudge drives adoption far faster than email asks; pair it with FIDO2-key handout sessions.

• **Match the method to the user.** FIDO2 keys for roaming/shared/admin users, Windows Hello for assigned PCs, certificate-based auth where a PKI/PIV already exists.

• **Use the built-in phishing-resistant strength when you can.** It tracks Microsoft's definition; build a custom strength only for a specific need, and name it `<Purpose> – <Scope> – <Stage>`.

• **Inventory legacy apps.** Find protocols/apps that can't honor modern auth before tenant-wide enforcement; scope or remediate them rather than poking permanent holes.

• **Measure coverage continuously.** Track registered phishing-resistant methods with `FIDO2-Report.ps1` and chase laggards with `FIDO2-Remediation.ps1` (default `-WhatIf`).

• **Name every object consistently.** Reuse `<Purpose> – <Scope> – <Stage>` for groups, strengths, and policies so the program is auditable and repeatable.

8. Deliverables Summary — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box
1. Solution Overview	What passwordless/phishing-resistant auth is; FIDO2 vs. Windows Hello vs. certificate-based; authentication strengths; benefits; limitations
2. Requirements Guide	Every prerequisite with Verify / Implement-if-missing
Global Requirements (Entra ID Solutions)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered Entra steps (methods, campaign, strength, Conditional Access)
5. Testing Guide	Validation procedures with pass/fail gates
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations

PowerShell scripts

Script	What it does
`FIDO2-Discovery.ps1`	Reports tenant authentication-method policy state (FIDO2 / Windows Hello / certificate-based enabled + targeting) — read-only
`FIDO2-Validation.ps1`	Confirms a user has a phishing-resistant method registered (and as default) — read-only
`FIDO2-Report.ps1`	Tenant credential-method coverage report from registration details (Microsoft Graph) — read-only

Script	What it does
`FIDO2-Remediation.ps1`	Safe remediation for weak-method users (default `-WhatIf`); flags users lacking a phishing-resistant method
`FIDO2-Set-RolloutTargeting.ps1`	Builds/populates the pilot and rollout Entra groups for staged targeting

What the buyer receives

- This implementation guide as a branded **Word** document and **PDF**.
- All five **PowerShell scripts** in a single ZIP.
- A repeatable process following the model: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand.**

Outcome

Users signing in passwordless with phishing-resistant credentials — FIDO2 keys and Windows Hello — and weak methods blocked by a Conditional Access authentication strength, proven on a pilot before fleet rollout.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

FIDO2-Discovery.ps1

FIDO2-Remediation.ps1

FIDO2-Report.ps1

FIDO2-Set-RolloutTargeting.ps1

FIDO2-Validation.ps1